CONFIDENTIAL **MOCK EXAM 2026**

GENERIC UNIVERSITY FINAL EXAMINATION

INSTRUCTIONS TO CANDIDATES

1. This question paper consists of two (2) parts: PART A (10 Questions)
   PART B (2 Questions)

2. Answer ALL questions in the Answer Booklet. Start each answer on a new page.

3. Do not bring any material into the examination room unless permission is given by the invigilator.

4. Please check to make sure that this examination pack consists of:

   i) the Question Paper
   ii) an Answer Booklet - provided by the Faculty

5. Answer ALL questions in English.

DO NOT TURN THIS PAGE UNTIL YOU ARE TOLD TO DO SO

This examination paper consists of 5 printed pages

PART A (80 MARKS)

QUESTION 1

a) Explain the difference between morals, ethics and laws as forms of guidance for professional conduct in computer security.

(2 marks)

b) Explain six requirements that a professional code of ethics and conduct, such as the ACM code, places on a computing professional's behaviour in security-related work.

(6 marks)

QUESTION 2

a) List two characteristics of Trojan horses as a type of malware, based on how they behave and what they do to the host system.

(2 marks)

b) Discuss six techniques by which malware attacks and propagates through computer systems, covering how malicious code is inserted into executables, how early viruses and worms spread, and how rootkits and spyware operate on infected hosts.

(6 marks)

QUESTION 3

a) List TWO (2) reasons why software is insecure, with particular reference to buffer overflows.

(2 marks)

b) State six (6) security mechanisms and components that Windows provides for managing users, controlling access and enforcing privileges, and note how the complexity of these mechanisms can itself become a security risk.

(6 marks)

QUESTION 4

a) State two impacts of malware attacks on the confidentiality, integrity or availability of a system's data and services.

(2 marks)

b) Describe the Samy worm as a case study of a cross-site scripting (XSS) attack, covering how the malicious script was injected, how it spread, and the outcome of the incident.

(6 marks)

QUESTION 5

a) State TWO (2) formal security models that are listed as key security models, and for each, state the specific security concern it addresses.

(2 marks)

b) Refer to your answer in (a). Explain how the access control matrix, access control lists and capabilities each implement access policies, and state one advantage and one disadvantage of the matrix and of the list structure.

(6 marks)

QUESTION 6

a) State TWO (2) ways in which an intrusion detection system supports the detection and defence of a system against attacks.

(2 marks)

b) Compare how a misuse detection system and an anomaly detection system each classify activity as an attack, and explain one limitation of each approach when used as a countermeasure against threats.

(6 marks)

QUESTION 7

a) Explain the goals of access control and the role of a reference monitor in realizing access control policies.

(2 marks)

b) State the Chinese Wall policy and explain its simple security rule and its *-property. Then explain why this policy is described as addressing a specialised concern and how its permissions differ from static access rights.

(6 marks)

QUESTION 8

a) Explain the two stages of the biometric authentication process and state what activities occur in each stage.

(2 marks)

b) Biometric technologies are grouped into different categories and each technology has its own operational characteristics. Explain the categories of biometric applications and the characteristics of iris and fingerprint technologies.

(6 marks)

QUESTION 9

a) Explain two password security controls that can be applied to password files and accounts to protect against unauthorised access.

(2 marks)

b) Describe six aspects of Kerberos and single sign-on mechanisms, covering the motivation for single sign-on, the design criteria of Kerberos, and how a user logs in to Kerberos.

(6 marks)

QUESTION 10

a) Explain how IDS sensors should be positioned in a network-based intrusion detection architecture, and give one typical location for such a sensor.

(2 marks)

b) Explain three preventive network security mechanisms that an organization can deploy to protect its network, describing for each mechanism how it controls or secures network traffic.

(6 marks)

PART B (20 MARKS)

QUESTION 1

A hospital is deploying a fleet of networked medical workstations and wants each machine to prove, at boot time, that only approved software is running before it is allowed onto the clinical network. The security team proposes basing this assurance on a hardware module fitted to every workstation.

a) Discuss how a Trusted Platform Module and a chain of trust can be used to establish that a platform is in a trusted state, referring in your answer to the roots of trust and to the role of the TPM in the boot process.

(5 marks)

b) In the hospital workstation deployment described in the scenario, the vendor proposes using the Next Generation Secure Computing Base rather than relying on the ordinary operating system. Explain the two primary system components of NGSCB and the role each plays in protecting the trusted mode of the workstation.

(5 marks)

QUESTION 2

A software house is drafting a code of ethics for its security team. A junior analyst asks why the team should adopt a documented code at all, and a manager warns that the code may not bind every member and may be hard to enforce.

a) Explain five points about the ethical impact of adopting a documented code of ethics for a professional computing group, covering what such a code is, how it is established, what it does, and the limitations that reduce its ethical impact.

(5 marks)

b) Referring to the scenario, state five points about the privacy responsibilities that a documented code of ethics places on the security team and the organisation, including the duties of individual specialists and the role of professional bodies' codes.

(5 marks)

END OF QUESTION PAPER